

CYBR 437 Secure Coding

Winter 2026

Lab - 7

Release date: February 17, 2026

Due date: February 23, 2026, at 11:59 pm

Introduction

This lab is a continuation of the return-oriented programming series. In it, you will continue to build on your experience analyzing 32-bit binaries to exploit buffer overflow vulnerabilities while chaining multiple return addresses to call functions in sequence. In doing so, you will take advantage of the 32-bit calling convention, where arguments are passed on the stack rather than in registers.

Setup

- A lab7 tarball is available for download from the Lab-7 assignment page, within it are 3 binary files: challenge1-3
- Upload the tarball to your VM and untar with the following commands:
 - `scp ./lab7.tar.gz [username]@[ip]:/[directory]`
 - `tar -xzf lab7.tar.gz`
- Make the binaries executable with the command `chmod +x <filename>`
- Install Capstone (a prerequisite for Ropper) and Ropper with the following commands to find gadgets
 - `sudo pip install capstone --break-system-packages`
 - `sudo pip install ropper --break-system-packages`

Challenges

Challenge 1

This challenge introduces return-oriented programming on a 32-bit binary. Building on your experience controlling the EIP, you will now redirect execution to a function that requires specific arguments to be passed correctly on the stack. Ensure that the program exits cleanly.

Challenge 2

This challenge extends your ROP experience by requiring you to call multiple functions in sequence. Each function should execute in the correct order to satisfy the program's conditions. Ensure that the program exits cleanly.

Challenge 3

This challenge is similar to challenge 2. You need to find the correct sequence to chain multiple functions together with appropriate parameter values and to ensure that the program exits cleanly.

Submission Instructions

Your write-up submission should include:

- For every problem, screen captures demonstrating:
 - Checking the binary file's endianness with the `file` command.
 - Checking which defenses have been turned on/off with `checksec`.
 - The use of `pwndbg` to illustrate how you arrived at the value of the `eip`.
 - Explanation of how you found the required gadgets, along with screenshots.
 - Your success in each challenge (screenshots should include the entire output).
- Detailed explanations of how you performed each attack, including payload descriptions.